



KKMTM

Driving Innovation, Elevating Technology

2026

ÉTUDE DES RISQUES MÉTHODE EBIOS RISK MANAGER

Système d'information industriel - Secteur Automobile & Aéronautique

Entreprise	KKMTM
Secteur	Industriel OT - Automobile et Aéronautique
Méthode	EBIOS Risk Manager (ANSSI / Club EBIOS)
Version	1.0
Date	28 Juin 2026
Statut	Validé
Classification	KKMTM Confidential
Rédacteur	MESQUITA DOS SANTOS Kévin
Validation	Direction Générale, Risk Manager, DSI, RSSI

Historique des modifications

Date	Version	Objet de la modification	Auteur(s)	Statut
28/06/2026	1.0	Création de l'étude des risques EBIOS RM de KKMTM : Analyse du projet sur l'hyperviseur Proxmox.	MESQUITA DOS SANTOS Kévin	Approuvé

Références documentaires

Référence	Description
PSSI	Politique de Sécurité des Systèmes d'Information, KKMTM 2026
Référentiel	Référentiel normatif et réglementaire de cybersécurité, KKMTM 2026
EBIOS Risk Manager	Méthode EBIOS Risk Manager, ANSSI, 2018
Club EBIOS	« Cybersécurité et protection de la vie privée - Exemple d'étude des risques », Club EBIOS, 18/06/2021

1. Positionnement du document

Le présent document présente l'analyse des risques de cybersécurité de KKMTM, réalisée selon la méthode EBIOS Risk Manager (EBIOS RM) de l'ANSSI. Elle porte sur l'ensemble du système d'information de l'entreprise, couvrant les environnements IT, DMZ et OT.

L'objectif est d'identifier les principaux risques pouvant affecter les activités de KKMTM, d'évaluer leur niveau de criticité et de définir les mesures de sécurité adaptées.

Cette étude s'inscrit dans la continuité de la PSSI et contribue à renforcer la sécurité du laboratoire cyber-OT.

Conformément à la méthode EBIOS RM, l'analyse est organisée en cinq ateliers : cadrage de l'étude, identification des sources de risque, construction des scénarios stratégiques et opérationnels, puis définition des mesures de traitement des risques.

1.1 Présentation de KKMTM

KKMTM est une entreprise spécialisée dans la conception et la sécurisation d'environnements industriels IT/OT. Dans le cadre de ce projet, elle s'appuie sur un laboratoire cyber-OT reproduisant une architecture industrielle réaliste, organisée autour des zones IT, DMZ et OT selon le modèle Purdue. Cet environnement intègre notamment un contrôleur de domaine, un bastion d'administration, un pare-feu, un serveur SCADA, un PLC simulé et des outils de supervision.

Le laboratoire est utilisé pour les activités de formation, de démonstration et de validation de solutions de cybersécurité. Les systèmes qu'il héberge ainsi que les configurations, scénarios d'attaque et données techniques qu'il contient doivent être protégés afin de garantir leur confidentialité, leur intégrité et leur disponibilité.

1.2 Objet et périmètre de l'étude

Conformément au périmètre défini par la PSSI, la présente étude EBIOS RM couvre l'ensemble des composants du laboratoire cyber-OT de KKMTM :

- Zone IT : postes d'administration, contrôleur de domaine, services DNS/DHCP et outils de gestion ;
- Zone DMZ : bastion d'administration, pare-feu, outils de supervision et de journalisation ;
- Zone OT : serveur SCADA, PLC simulé, réseau industriel et équipements de simulation ;
- Infrastructure : plateforme Proxmox ou Qemu / KVM, playbooks Ansible, dépôt Git et solutions de sauvegarde.

Sont exclus du périmètre les risques ne relevant pas de la cybersécurité, tels que les risques physiques, les risques financiers ou les événements sans impact sur le système d'information.

1.3 Cadre normatif et réglementaire applicable

En cohérence avec le Référentiel normatif et réglementaire de KKMTM, l'étude s'appuie sur les cadres suivants, mobilisés comme grilles de lecture pour la gestion des risques et la définition des mesures de sécurité :

Référentiel	Usage dans l'étude
ISO/IEC 27001 / 27002 / 27005	Gouvernance du SMSI, catalogue de bonnes pratiques, méthodologie de gestion des risques applicable à l'IT, à la DMZ et à l'OT.
IEC 62443 (1-1, 2-1/2-4, 3-2, 3-3)	Cadre de référence pour la cybersécurité des systèmes d'automatisation et de contrôle industriel (IACS) : zonage, conduits, exigences techniques et organisationnelles.
Directive NIS2 (UE)	Référentiel de bonnes pratiques pris en compte pour renforcer la cybersécurité et la résilience des systèmes d'information.
Cyber Resilience Act (CRA)	Référentiel pris en compte pour intégrer les exigences de cybersécurité applicables aux produits et logiciels utilisés dans le laboratoire.
RGPD	Protection des données à caractère personnel traitées par les systèmes IT/OT (collaborateurs, contacts partenaires).
ISO 22301	Management de la continuité d'activité, plans de reprise (PRA/PCA).

1.4 Gouvernance de l'étude

Acteur	Rôle	Contribution à l'étude
Direction Générale	Commanditaire	Valide le périmètre, arbitre les risques critiques, accepte les risques résiduels.
MESQUITA DOS SANTOS Kevin	RSSI - Pilote de l'étude	Anime les ateliers, rédige l'étude, propose le plan de traitement, assure le suivi.
DSI	Contributeur	Apporte la connaissance de l'architecture IT et des applications métier.
Responsables OT	Contributeur	Apporte la connaissance des automates, du SCADA et des contraintes de production.
CAUDAN Théo	Ingénieur cybersécurité OT - Contributeur	Apporte l'expertise sur la segmentation IT/DMZ/OT et les protocoles industriels.
ADDI Mahmoud	Pentester / Red Team - Contributeur	Challenge la vraisemblance des scénarios d'attaque retenus.

2. Atelier 1 - Cadrage et socle de sécurité

2.1 Missions et valeurs métier

Valeur métier	Enjeux associés
Assurer la disponibilité du laboratoire cyber-OT	Garantir le fonctionnement des services IT, DMZ et OT nécessaires aux démonstrations et aux exercices.
Protéger les configurations et les données techniques	Préserver les configurations des systèmes, les playbooks Ansible, les dépôts Git et les scénarios de test.
Garantir l'intégrité des environnements	Éviter toute modification non autorisée des machines virtuelles, des équipements et des configurations réseau.
Assurer la continuité des activités	Permettre une reprise rapide après un incident grâce au PRA, au PCA et aux sauvegardes.
Respecter les exigences de sécurité	Appliquer la PSSI ainsi que les référentiels et bonnes pratiques retenus pour le projet. (NIS2, RGPD, CRA, ISO/IEC 27001, IEC 62443)

2.2 Biens supports

Le tableau ci-dessous présente les principaux biens supports du laboratoire cyber-OT.

Zone	Bien support	Valeurs métier portées
Infrastructure	Plateforme Proxmox / Qemu-KVM	Disponibilité du laboratoire, continuité des activités
IT	Contrôleur de domaine Active Directory	Authentification, contrôle des accès
IT	Serveurs DNS et DHCP	Fonctionnement des services réseau
DMZ	Bastion d'administration	Administration sécurisée des systèmes
DMZ	Pare-feu	Protection des flux entre les zones
DMZ	SIEM et outils de supervision	Détection des incidents et journalisation
OT	SCADA (supervision industrielle)	Supervision du procédé industriel
OT	Automates programmables (PLC)	Pilotage et simulation du procédé
OT	Interfaces homme-machine (IHM)	Continuité de la production
OT	Réseaux industriels et protocoles de terrain	Communications entre les équipements OT
Infrastructure	Dépôt Git, playbooks Ansible et sauvegardes	Configuration, automatisation et reprise d'activité

2.3 Échelle de gravité

L'échelle de gravité retenue par KKMTM prend en compte les impacts financiers, opérationnels, d'image et réglementaires, ainsi que les conséquences sur le fonctionnement et la sécurité du laboratoire cyber-OT.

Gravité	Financier	Production / fonctionnement	Image	Juridique / réglementaire	Sûreté / sécurité des opérateurs
Maximale	Perte supérieure au budget annuel alloué au laboratoire	Indisponibilité complète du laboratoire empêchant toute activité de formation ou de démonstration	Atteinte durable à la crédibilité de KKMTM auprès de l'établissement	Non-respect des exigences réglementaires ou des politiques internes pouvant entraîner des sanctions	Compromission majeure de l'infrastructure ou perte totale des environnements de simulation
Importante	Perte comprise entre 25 % et 100 % du budget annuel	Indisponibilité prolongée d'un ou plusieurs services critiques (AD, SCADA, Proxmox, SIEM...)	Dégradation de l'image auprès des utilisateurs ou partenaires du projet	Non-conformité nécessitant des actions correctives	Dysfonctionnement important affectant les scénarios de simulation
Significative	Perte inférieure à 25 % du budget annuel	Perturbation temporaire des activités sans arrêt complet du laboratoire	Dégradation ponctuelle de l'image sans conséquence durable	Écart de conformité rapidement corrigé	Incident technique limité, sans impact majeur sur le fonctionnement
Minimale	Perte inférieure à 2 000 €	Perturbation mineure sans impact sur le déroulement des activités du laboratoire	Impact limité, sans conséquence durable sur l'image de KKMTM	Aucune conséquence réglementaire	Aucun impact sur fonctionnement la sécurité du laboratoire

2.4 Événements redoutés

Le tableau suivant présente les événements redoutés identifiés pour le laboratoire cyber-OT de KKMTM. Pour chacun d'eux sont précisés le ou les critères de sécurité impactés (Disponibilité, Intégrité, Confidentialité), le niveau de gravité retenu ainsi que leur prise en compte dans la suite de l'étude.

Événement redouté	D	I	C	Gravité	Retenu
ER1 - Indisponibilité du laboratoire cyber-OT empêchant la réalisation des activités de formation, de démonstration ou de test.	X			Maximale	Oui
ER2 - Altération de la configuration du SCADA ou du PLC simulé entraînant un comportement erroné des scénarios de simulation.		X		Maximale	Oui
ER3 - Fuite de configurations, de scripts ou de documentation technique vers une personne non autorisée.			X	Importante	Oui
ER4 - Divulgence d'informations relatives au laboratoire ou aux scénarios pédagogiques.			X	Significative	Oui
ER5 - Compromission d'un compte administrateur permettant une modification non autorisée de l'infrastructure.		X	X	Importante	Oui
ER6 - Indisponibilité des services d'infrastructure (Active Directory, DNS, Proxmox ou réseau) à la suite d'une cyberattaque ou d'une erreur de configuration.	X			Importante	Oui
ER7 - Perte ou corruption des sauvegardes empêchant la restauration complète du laboratoire.	X	X		Importante	Oui
ER8 - Perte de la supervision ou de la collecte des journaux de sécurité (SIEM), réduisant la capacité de détection des incidents.	X			Significative	Non

2.5 Évaluation de la conformité au socle de sécurité (PSSI)

Chapitre PSSI	Statut	Constat
Gouvernance et responsabilités	OK	Les rôles et responsabilités (Direction, RSSI, administrateurs et responsable OT) sont définis et documentés.
Gestion des accès et authentification	NOK	Le principe du moindre privilège est appliqué. Le déploiement de l'authentification multi-facteur (MFA) sur l'ensemble des accès d'administration reste à finaliser.
Sécurité réseau et systèmes	À vérifier	La segmentation IT/DMZ/OT est en place. Certains composants du laboratoire et l'environnement de virtualisation nécessitent encore des mesures d'isolation complémentaires.
Sécurité physique	OK	L'accès aux équipements du laboratoire et aux serveurs est limité aux personnes autorisées.
Sécurité des tiers et prestataires	À vérifier	Les accès des intervenants externes sont encadrés, mais les procédures de contrôle et de revue des habilitations peuvent être renforcées.
Gestion des incidents	OK	Une procédure de déclaration, de traitement et d'escalade des incidents est définie dans la PSSI.
Sensibilisation et formation	OK	Les membres de l'équipe projet sont sensibilisés aux bonnes pratiques de cybersécurité et participent à des exercices réguliers.
Conformité et audit	NOK	Les audits de sécurité et les revues de configuration ne sont pas encore réalisés de manière régulière sur l'ensemble du laboratoire.

3. Atelier 2 - Sources de risque

3.1 Matrice de pertinence (motivation × ressources)

La pertinence d'un couple source de risque / objectif visé (SR/OV) est évaluée en fonction de deux critères : la motivation de la source de risque et les ressources dont elle dispose. Le croisement de ces deux critères permet d'estimer le niveau de pertinence du scénario.

Ressources \ Motivation	1- Faible	2 - Moyenne	3 - Forte
3 - Importantes	Moyen	Élevé	Élevé
2 - Modérées	Faible	Moyen	Élevé
1 - Faibles	Faible	Faible	Moyen

3.2 Sources de risque et objectifs visés retenus

Source de risque	Objectif visé	Motivation	Ressources	Pertinence	Retenu
Administrateur de l'infrastructure Proxmox ESGI	Modification involontaire de la configuration ou indisponibilité de la plateforme de virtualisation.	Faible	Importantes	Élevé	Oui
Utilisateur d'un autre projet ou d'une autre filière sur l'infrastructure mutualisée	Accéder aux ressources du laboratoire ou perturber involontairement son fonctionnement.	Moyenne	Modérées	Élevé	Oui
Cybercriminel (ransomware)	Chiffrer les systèmes afin d'obtenir une rançon et rendre le laboratoire indisponible.	Forte	Modérées	Élevée	Oui
Concurrent ou acteur malveillant	Obtenir des configurations, scripts ou documentations techniques du laboratoire.	Moyenne	Modérées	Moyen	Oui
Prestataire ou intervenant disposant d'un accès au laboratoire	Exploiter un accès légitime pour compromettre l'infrastructure.	Moyenne	Modérées	Moyen	Oui
Collaborateur ou administrateur malveillant	Modifier, supprimer ou divulguer des informations sensibles.	Moyenne	Modérées	Moyen	Oui
Attaquant opportuniste	Tester ses capacités techniques ou exploiter une vulnérabilité.	Faible	Faibles	Faible	Oui

3.3 Croisement sources de risque / événements redoutés

Le tableau ci-dessous relie chaque source de risque retenue aux événements redoutés qu'elle est susceptible de provoquer, faisant le pont entre le point de vue de l'attaquant et celui du défenseur :

Source de risque	ER1 Indisponibilité du laboratoire	ER2 Altération du SCADA / PLC	ER3 Fuite de configurations et scripts	ER4 Divulgence d'informations	ER5 Compromission d'un compte administrateur
Administrateur de l'infrastructure Proxmox ESGI	X				
Utilisateur d'un autre projet ou d'une autre filiale	X	X			X
Cybercriminel (ransomware)	X				X
Collaborateur ou administrateur malveillant	X	X	X	X	X
Prestataire ou intervenant disposant d'un accès	X	X	X		X
Attaquant opportuniste					X

4. Ateliers 3 et 4 - Scénarios stratégiques et opérationnels

4.1 Critères et échelle de dangerosité des parties prenantes

La dangerosité des parties prenantes est évaluée à partir de quatre critères : la dépendance, la pénétration, la maturité et la confiance, conformément à la méthode EBIOS Risk Manager.

Niveau	Dépendance	Pénétration	Maturité	Confiance
1	La partie prenante n'est pas nécessaire au fonctionnement ou à la restauration du laboratoire.	Aucun accès ou accès très limité aux ressources du laboratoire.	Les bonnes pratiques de sécurité sont peu ou pas appliquées.	Le niveau de confiance est inconnu ou ne peut être évalué.
2	La partie prenante peut contribuer ponctuellement au fonctionnement ou à la restauration.	Accès utilisateur à certains services ou ressources.	Des mesures de sécurité sont appliquées, mais de manière incomplète.	Les intentions sont considérées comme neutres.
3	La partie prenante joue un rôle important dans l'exploitation ou l'administration du laboratoire.	Accès administrateur à plusieurs composants de l'infrastructure.	Les bonnes pratiques de sécurité sont appliquées de manière régulière.	Les intentions sont connues et jugées fiables.
4	La partie prenante est indispensable au fonctionnement ou à la restauration du laboratoire.	Accès complet à l'infrastructure, à la plateforme Proxmox ou aux équipements critiques.	La sécurité est pleinement intégrée dans les procédures d'administration.	La partie prenante est pleinement identifiée et bénéficie d'un niveau de confiance élevé.

4.2 Cartographie de l'écosystème et dangerosité des parties prenantes

Catégorie	Partie prenante	Dép.	Pén.	Mat.	Conf.	Dangerosité	Zone
Infrastructure	Administrateur de la plateforme Proxmox (école)	4	4	4	4	1,0	Contrôle
Utilisateurs	Étudiants d'autres projets utilisant le même pool Proxmox	3	3	2	2	2,3	Danger
Équipe projet	Administrateurs du laboratoire KKMTM	4	4	3	4	1,3	Contrôle
Équipe projet	Utilisateurs du laboratoire	2	2	3	4	0,3	Confiance
Infrastructure	Services informatiques de l'établissement	4	4	4	4	1,0	Contrôle
Prestataires	Fournisseurs des solutions utilisées (Proxmox, Microsoft, GitHub, etc.)	2	2	4	3	0,3	Confiance

4.3 Échelle de vraisemblance

Niveau	Définition
4 - Certain ou déjà produit	Le scénario s'est déjà produit au sein du laboratoire ou présente une très forte probabilité de survenir au regard de son environnement (ex. erreur sur le pool Proxmox mutualisé, modification involontaire d'une configuration).
3 - Très vraisemblable	La source de risque dispose des moyens et des accès nécessaires pour atteindre son objectif en s'appuyant sur des techniques connues ou des vulnérabilités identifiées.
2 - Vraisemblable	Le scénario est possible mais nécessite des conditions particulières ou l'exploitation d'une faiblesse de sécurité.
1 - Invraisemblable	Le scénario est peu probable compte tenu des mesures de sécurité en place et des moyens dont dispose la source de risque.

4.4 Scénarios stratégiques retenus

Les scénarios stratégiques ci-dessous ont été construits à partir des sources de risque identifiées et des principaux événements redoutés. Ils représentent les chemins d'attaque les plus plausibles dans le contexte du laboratoire cyber-OT de KKMTM.

Réf.	Scénario stratégique	Source de risque
S1	Un utilisateur d'un autre projet intervenant sur le même pool Proxmox modifie involontairement une configuration réseau ou une machine virtuelle, entraînant l'indisponibilité du laboratoire.	Utilisateur d'un autre projet
S2	L'administrateur de la plateforme Proxmox effectue une modification de configuration ou une opération de maintenance ayant pour conséquence l'arrêt des machines virtuelles du laboratoire.	Administrateur Proxmox
S3	Un cybercriminel compromet un poste d'administration et déploie un ransomware provoquant l'indisponibilité des services critiques et des sauvegardes.	Cybercriminel
S4	Un administrateur ou un membre du projet modifie ou supprime accidentellement une configuration critique, entraînant une interruption des services du laboratoire.	Collaborateur ou administrateur
S5	Un attaquant exploite une vulnérabilité d'un service exposé afin d'obtenir un accès au système d'information et d'élever ses privilèges.	Attaquant opportuniste
S6	Un compte administrateur est compromis, permettant à un attaquant de modifier les configurations du laboratoire et d'accéder aux données sensibles.	Cybercriminel / Collaborateur malveillant
S7	Une erreur de manipulation ou une corruption des sauvegardes empêche la restauration complète du laboratoire après un incident majeur.	Administrateur / Défaillance technique

4.5 Matrice de risque initiale (avant traitement complémentaire)

Gravité \ Vraisemblance	1	2	3	4
4 - Maximale		S5	S3	S1 / S2
3 - Importante		S7	S4 / S6	
2 - Significative				
1 - Minimale				

4.6 Déclinaison en scénarios opérationnels

Les scénarios stratégiques les plus critiques sont déclinés ci-dessous en scénarios opérationnels. Chaque scénario présente les principales étapes de l'attaque ou de l'incident ainsi que les mesures de sécurité permettant d'en limiter les conséquences.

S1 - Modification involontaire de l'infrastructure par un utilisateur d'un autre projet

Étape	Action ou événement	Vraisemblance	Mesure(s)
1	Connexion d'un utilisateur au pool Proxmox mutualisé.	4	Gestion des comptes et des habilitations
3	Modification involontaire d'une VM, d'un VLAN ou d'une configuration réseau.	4	Cloisonnement des ressources, contrôle des droits
4	Indisponibilité d'un ou plusieurs services du laboratoire.	4	Sauvegardes régulières, supervision
5	Restauration de l'environnement à partir des sauvegardes.	3	PRA, sauvegardes testées

S2 - Modification de la plateforme Proxmox par l'administrateur de l'infrastructure

Étape	Action ou événement	Vraisemblance	Mesure(s)
1	Intervention de maintenance sur la plateforme Proxmox.	3	Procédures de changement
2	Modification de la configuration réseau ou arrêt d'un nœud.	3	Validation des changements
3	Indisponibilité des machines virtuelles du laboratoire.	4	Sauvegardes, supervision
4	Remise en service de l'infrastructure.	3	PRA, coordination avec le service informatique

S3 - Déploiement d'un ransomware

Étape	Action ou événement	Vraisemblance	Mesure(s)
1	Compromission d'un poste d'administration.	2	Sensibilisation, antivirus
2	Élévation de privilèges et déplacement latéral.	2	Segmentation réseau, moindre privilège
3	Chiffrement des serveurs et des données.	2	Sauvegardes, supervision
4	Restauration des services critiques.	2	PRA, PCA, sauvegardes vérifiées

5. Atelier 5 - Traitement du risque

5.1 Matrice de niveau de risque et stratégies de traitement

Le niveau de risque est déterminé en fonction de la gravité et de la vraisemblance de chaque scénario. Cette évaluation permet de définir la stratégie de traitement la plus adaptée.

Niveau de risque	Description	Stratégie de traitement
Acceptable	Le risque présente une gravité et une vraisemblance faibles.	Le risque peut être accepté tout en maintenant les mesures de sécurité existantes.
Vigilance	Le risque nécessite une attention particulière en raison de son impact ou de sa probabilité.	Des mesures techniques ou organisationnelles complémentaires sont mises en place afin de réduire le risque.
Inacceptable	Le risque présente une gravité et/ou une vraisemblance élevée.	Le risque doit être traité en priorité avant toute acceptation. Des mesures correctives sont mises en œuvre et leur efficacité est vérifiée.

5.2 Risques appréciés sous forme de scénarios

Le tableau suivant présente les scénarios stratégiques retenus, leur niveau de gravité, leur vraisemblance ainsi que les principales mesures de traitement envisagées.

Réf.	Scénario (rappel synthétique)	Gravité	Vraisemblance	Mesures
S1	Modification involontaire de l'environnement par un utilisateur d'un autre projet.	4	4	Cloisonnement des ressources, gestion des habilitations, sauvegardes, PRA.
S2	Indisponibilité de la plateforme Proxmox à la suite d'une opération d'administration.	4	4	Procédure de changement, sauvegardes, supervision, PRA.
S3	Déploiement d'un ransomware sur les services du laboratoire.	4	3	Sensibilisation, segmentation réseau, antivirus, sauvegardes, PRA/PCA.
S4	Erreur ou action malveillante d'un membre de l'équipe projet.	3	3	Gestion des droits, journalisation, principe du moindre privilège.
S5	Exploitation d'une vulnérabilité permettant un accès non autorisé.	4	2	Mises à jour de sécurité, durcissement des systèmes, supervision.
S6	Compromission d'un compte administrateur.	3	3	Authentification multi-facteur, mots de passe robustes, contrôle des accès privilégiés.
S7	Perte ou corruption des sauvegardes empêchant la restauration du laboratoire.	3	2	Sauvegardes régulières, stockage séparé, tests de restauration.

5.3 Plan d'action

Le plan d'action suivant regroupe les principales mesures retenues à l'issue de l'analyse EBIOS RM afin de réduire les risques identifiés.

Code	Action	Responsable	Échéance
PA1	Renforcer le cloisonnement de l'environnement sur le pool Proxmox et limiter les accès des autres projets lorsque cela est possible.	Équipe Infrastructure	Avant soutenance
PA2	Généraliser l'utilisation de mots de passe robustes et de l'authentification multi-facteur pour les comptes d'administration lorsque la solution le permet.	Administrateur système	Avant soutenance
PA3	Centraliser les journaux des principales machines dans le SIEM afin de faciliter la détection des événements.	Équipe projet	Avant soutenance
PA4	Vérifier régulièrement les sauvegardes des machines virtuelles et tester les procédures de restauration prévues par le PRA.	Administrateur système	Mensuel
PA5	Contrôler régulièrement les règles de filtrage entre les zones IT, DMZ et OT.	Administrateur réseau	Trimestriel
PA6	Maintenir les machines virtuelles et les applications du laboratoire à jour afin de limiter les vulnérabilités connues.	Équipe projet	Mensuel
PA7	Mettre à jour la documentation technique (architecture, procédures de déploiement, PRA, PCA et PSSI) après chaque évolution importante.	Chef de projet	En continu
PA8	Réaliser régulièrement des tests de restauration et des exercices de gestion d'incident afin de valider les procédures mises en place.	Équipe projet	Annuel

5.4 Matrice de risque résiduelle (après mise en œuvre du plan d'action)

Gravité \ Vraisemblance	1	2	3	4
4		S3	S1 / S2	
3		S4 / S6		
2	S7	S5		
1				

5.5 Détail des risques résiduels

Réf.	Risque résiduel	Gravité (initiale → résiduelle)	Vraisemblance (initiale → résiduelle)	Argumentaire
S1	Modification involontaire de l'environnement par un utilisateur d'un autre projet.	4 → 4	4 → 3	Le cloisonnement des ressources, la gestion des habilitations et les sauvegardes réduisent la probabilité d'occurrence. Le risque reste élevé en raison de la mutualisation de la plateforme Proxmox, qui n'est pas entièrement maîtrisée par l'équipe projet.
S2	Indisponibilité de la plateforme Proxmox à la suite d'une opération d'administration.	4 → 4	4 → 3	Les procédures de changement, la supervision et le PRA permettent de réduire l'impact opérationnel. L'équipe projet restant dépendante du service informatique de l'établissement, le risque ne peut être totalement supprimé.
S3	Déploiement d'un ransomware sur les services du laboratoire.	4 → 4	3 → 2	Les sauvegardes, la segmentation réseau, les mises à jour régulières et la sensibilisation diminuent la probabilité de réussite d'une attaque. L'impact reste maximal en cas de compromission.
S4	Erreur ou action malveillante d'un membre de l'équipe projet.	3 → 3	3 → 2	La limitation des privilèges, la journalisation et les revues de droits réduisent le risque sans pouvoir l'éliminer totalement.
S5	Exploitation d'une vulnérabilité permettant un accès non autorisé.	4 → 4	2 → 2	Les mises à jour de sécurité et le durcissement des systèmes limitent les possibilités d'exploitation, mais de nouvelles vulnérabilités peuvent apparaître.
S6	Compromission d'un compte administrateur.	3 → 3	3 → 2	L'authentification multifacteur, les mots de passe robustes et le contrôle des accès privilégiés réduisent la probabilité de compromission.
S7	Perte ou corruption des sauvegardes du laboratoire.	3 → 3	2 → 1	Les sauvegardes régulières, leur stockage sur un support distinct et les tests de restauration limitent fortement ce risque, qui reste néanmoins présent en cas de défaillance technique majeure.

6. Conclusion

Cette étude EBIOS Risk Manager a permis d'identifier les principaux risques de cybersécurité susceptibles d'affecter le laboratoire cyber-OT de KKMTM. Les différents ateliers ont mis en évidence plusieurs scénarios de risque, dont les plus critiques concernent l'indisponibilité de la plateforme Proxmox, la modification involontaire de l'environnement par un utilisateur d'un autre projet et le déploiement d'un ransomware sur les services du laboratoire.

Le plan d'action proposé vise à réduire ces risques en renforçant le cloisonnement des environnements, la protection des comptes administrateurs, la supervision, la gestion des sauvegardes et les procédures de reprise d'activité. Ces mesures permettent de limiter la probabilité de survenue des incidents tout en améliorant la capacité de réaction en cas de défaillance.

À l'issue de cette analyse, les risques résiduels sont considérés comme maîtrisés au regard du périmètre du projet. Les scénarios liés à la mutualisation de la plateforme Proxmox restent toutefois les plus sensibles, l'équipe projet demeurant dépendante de l'infrastructure de l'établissement et de son administration. Cette dépendance justifie le maintien des mesures de surveillance, des sauvegardes régulières ainsi que des tests du PRA et du PCA.

Cette étude s'inscrit dans la continuité de la PSSI et des autres documents de sécurité réalisés dans le cadre du projet. Elle constitue une base de référence qui pourra être mise à jour en fonction des évolutions du laboratoire, de l'ajout de nouveaux composants ou de l'apparition de nouveaux scénarios de menace.